

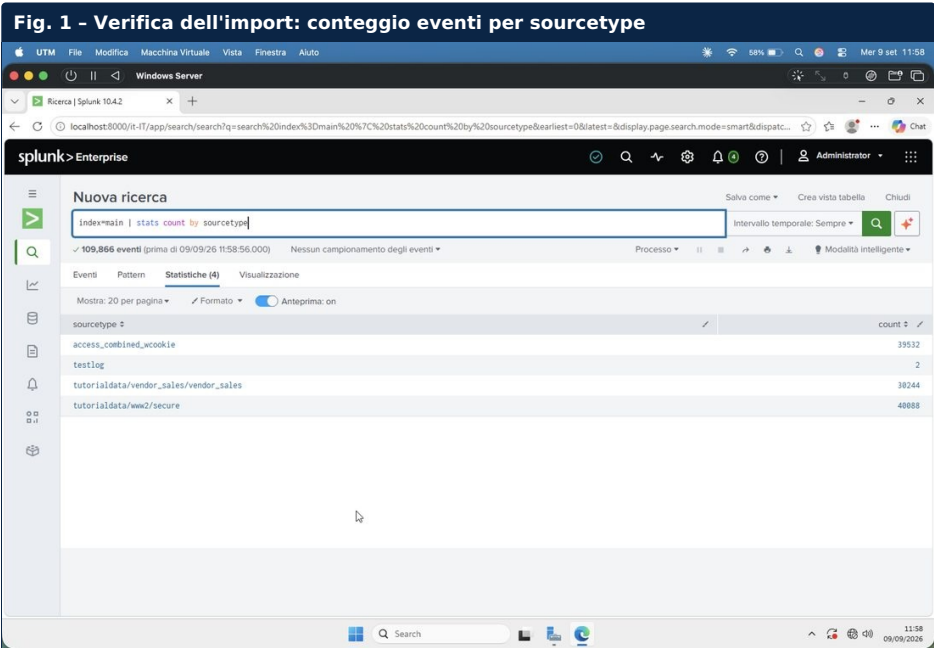
Bonus 3 - Splunk Haunting

Threat hunting e incident response su log SSH e web · EPICODE Cyber Security & Ethical Hacking

Autore: Francesco Terracciano · **Data:** 9 settembre 2026 · **Piattaforma:** Splunk Enterprise 10.4.2 (Windows Server su UTM) · **Dataset:** tutorialdata.zip
Obiettivo: analisi dei log tramite query SPL, rilevamento di attacchi brute force e verifica di eventuali compromissioni

1. Importazione del dataset

Il dataset tutorialdata.zip è stato importato in Splunk tramite la funzione *Add Data → Carica*, lasciando il riconoscimento automatico dei tipi di sorgente. L'indicizzazione ha prodotto complessivamente **109.866 eventi**. La verifica dei sourcetype mostra le tre sorgenti principali del dataset.

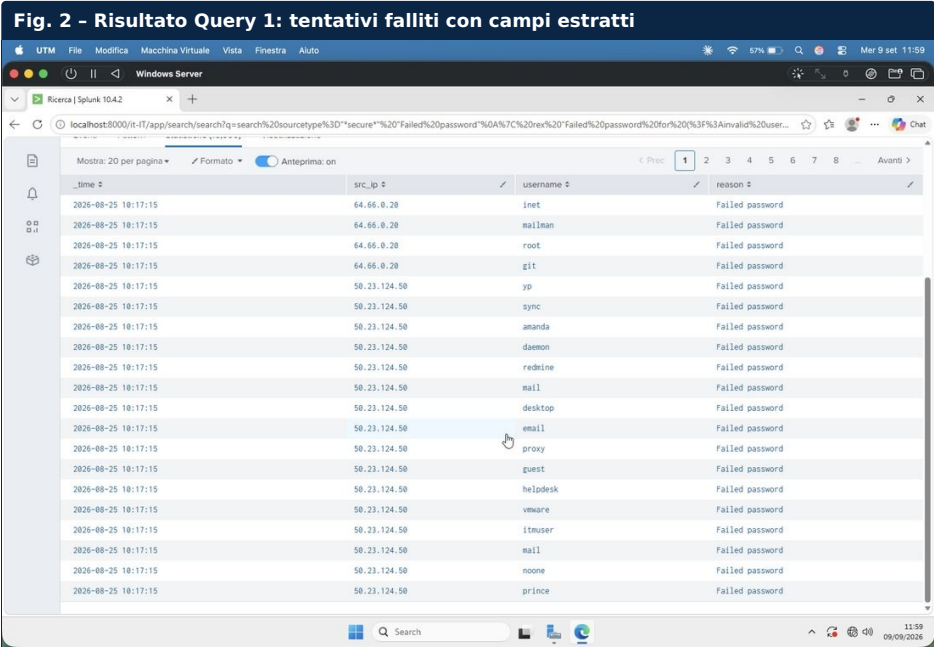


I log di autenticazione SSH risiedono nel sourcetype tutorialdata/www2/secure (40.088 eventi), mentre i log web sono in access_combined_wcookie (39.532 eventi). Nelle query seguenti i log di autenticazione sono filtrati con sourcetype="*secure*" per robustezza, e i log web con il rispettivo sourcetype.

2. Query 1 - Tentativi di accesso falliti

Identificazione dei tentativi di login falliti («Failed password»), con estrazione dei campi non indicizzati tramite rex e presentazione in tabella di timestamp, IP sorgente, username e motivo.

```
sourcetype="*secure*" "Failed password"
| rex "Failed password for (?:(invalid user) )?(?(<username>\$) from (?(<src_ip>\d+\.\d+\.\d+\.\d+) port (?(<port>\d+) )"
| eval reason="Failed password"
| table _time, src_ip, username, reason
| sort -_time
```



Già da questo primo risultato emerge un pattern sospetto: lo stesso IP sorgente compie numerosi tentativi con username diversi nello stesso istante (10:17:15), indizio caratteristico di un attacco automatizzato di tipo *user enumeration*.

3. Query 2 - Sessioni SSH riuscite per l'utente djohnson

Ricerca delle autenticazioni riuscite («Accepted password») per l'utente djohnson, con timestamp e identificativo utente.

```
sourcetype="**secure*" "Accepted password" djohnson
| rex "Accepted password for (?<username>\$+) from (?<src_ip>\d+.\d+.\d+.\d+) port (?<port>\d+)"
| table _time, username
| sort - time
```

Fig. 3 - Risultato Query 2: accessi riusciti di djohnson

[illegible]

4. Query 3 - Tentativi falliti dall'IP 86.212.199.60

Isolamento dei tentativi falliti provenienti da un IP specifico, con estrazione della porta sorgente (campo non indicizzato) tramite rex.

```
sourcetype="*secure*" "Failed password" "86.212.199.60"
| rex "Failed password for (?:(invalid user )?(?\S+) from (?<src_ip>\d+\.\d+\.\d+\.\d+) port (?<port>\d+)"
| table _time, username, port
| sort - time
```

Fig. 4 - Risultato Query 3: 158 tentativi dal singolo IP, porta estratta

The screenshot shows the Splunk Enterprise web interface. At the top, there's a navigation bar with the Splunk logo and 'Enterprise' text. Below it, a search bar contains the query: `sourcetype="secure" "Failed password" "86.212.199.68" | rex "Failed password for (?invalid user)?(?username)>|s" from (?src_ip|d\.\d\.\d\.\d) port (?port|d+)" | table _time, username, port | sort _time`. The search results are displayed in a table with columns: `_time`, `username`, and `port`. The table shows 15 events, all with a timestamp of 2026-08-25 10:17:15. The usernames listed are: `apushot`, `tomcat`, `desktop`, `yp`, `mail`, `apache`, `services`, `irc`, `mysql`, `pmuser`, `ventrillo`, and `system`. The ports listed are: 3692, 1464, 3518, 2856, 1054, 2610, 4740, 1203, 4892, 1775, 1465, and 3305.

L'IP 86.212.199.60 genera **158 tentativi falliti** concentrati in un solo istante, contro decine di username diversi e da porte sorgente differenti: la firma inequivocabile di un attacco brute force automatizzato.

5. Query 4 - Rilevamento brute force (IP con > 5 tentativi)

Aggregazione dei tentativi falliti per IP sorgente e applicazione della soglia richiesta (> 5 fallimenti), per elencare tutti gli indirizzi coinvolti in attacchi di forza bruta.

```
sourcetype="*secure*" "Failed password"
| rex "Failed password for (?<invalid user >)?(?<username>\$+) from (?<src_ip>\d+\.\d+\.\d+\.\d+) port (?<port>\d+)"
| stats count as tentativi_falliti by src_ip
| where tentativi_falliti > 5
| sort -tentativi_falliti
```

Fig. 5 - Risultato Query 4: 182 IP attaccanti ordinati per intensità

src_ip	tentativi_falliti
87.194.216.51	948
211.166.11.101	743
128.241.220.82	622
109.169.32.135	515
194.215.205.19	514
216.221.226.11	433
188.138.40.166	297
65.19.167.94	286
107.3.146.207	282
95.130.170.231	279
223.205.219.67	274

Sono **182 gli IP** che superano la soglia, su un totale di 33.253 tentativi falliti. I più aggressivi raggiungono numeri elevatissimi: 87.194.216.51 (948 tentativi), 211.166.11.101 (743), 128.241.220.82 (622). Questa è la prova di una campagna brute force distribuita su larga scala.

6. Query 5 - Isolamento degli Internal Server Error (HTTP 500)

Estrazione di tutti gli errori 500 dai log web, con dettaglio di client, metodo e risorsa richiesta.

```
sourcetype="access_combined_wcookie" status=500
| table _time, clientip, method, uri_path, status
| sort -_time
```

Fig. 6 - Risultato Query 5: errori HTTP 500 isolati

_time	clientip	method	uri_path	status
2026-08-25 18:18:59	198.35.1.75	GET	/cart.do	500
2026-08-25 18:18:55	198.35.1.75	GET	/product.screen	500
2026-08-25 17:42:03	125.89.78.6	POST	/cart.do	500
2026-08-25 17:17:00	194.146.236.22	POST	/product.screen	500
2026-08-25 17:15:13	121.254.179.199	POST	/product.screen	500
2026-08-25 16:54:07	76.89.103.115	GET	/cart.do	500
2026-08-25 16:33:02	59.36.99.70	GET	/oldlink	500
2026-08-25 16:05:47	201.42.223.29	GET	/category.screen	500
2026-08-25 15:44:56	188.173.152.100	GET	/category.screen	500
2026-08-25 15:26:14	187.231.45.62	POST	/product.screen	500
2026-08-25 15:09:37	92.46.53.223	GET	/category.screen	500
2026-08-25 15:02:37	95.163.78.227	GET	/oldlink	500
2026-08-25 14:38:53	201.122.42.235	POST	/product.screen	500
2026-08-25 14:32:20	175.44.26.139	GET	/product.screen	500
2026-08-25 14:06:44	209.114.36.109	GET	/category.screen	500
2026-08-25 14:01:34	60.220.218.88	GET	/cart.do	500
2026-08-25 13:18:16	170.192.178.10	GET	/category.screen	500
2026-08-25 12:53:45	61.164.73.20	GET	/product.screen	500
2026-08-25 12:46:55	211.25.254.234	POST	/cart.do	500
2026-08-25 12:40:09	62.216.64.19	GET	/cart.do	500

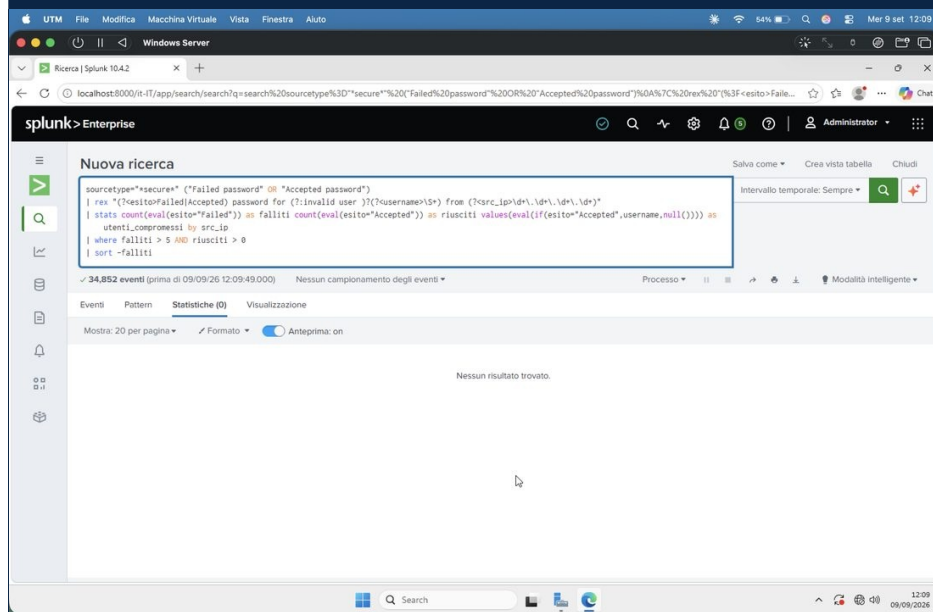
Gli errori 500 si concentrano sulle pagine applicative del sito (/cart.do, /product.screen, /category.screen), da investigare separatamente come possibile problema di stabilità applicativa o effetto di attività di scanning.

7. Fase di analisi ed incident response

La domanda centrale dell'incident response non è «ci sono stati attacchi?» (la Query 4 lo conferma) ma «**qualcuno è riuscito ad entrare?**». Un brute force fallito è rumore; un brute force seguito da un accesso riuscito è una compromissione. La query seguente correla i due esiti per ogni IP.

```
sourcetype="*secure*" ("Failed password" OR "Accepted password")
| rex "(?<esito>Failed|Accepted) password for (?::invalid user )?(?<username>\S+) from (?<src_ip>\d+\.\d+\.\d+\.\d+)"
| stats count(eval(esito="Failed")) as falliti count(eval(esito="Accepted")) as riusciti by src_ip
| where falliti > 5 AND riusciti > 0
| sort -falliti
```

Fig. 7 - Correlazione brute force / accessi riusciti: nessun risultato



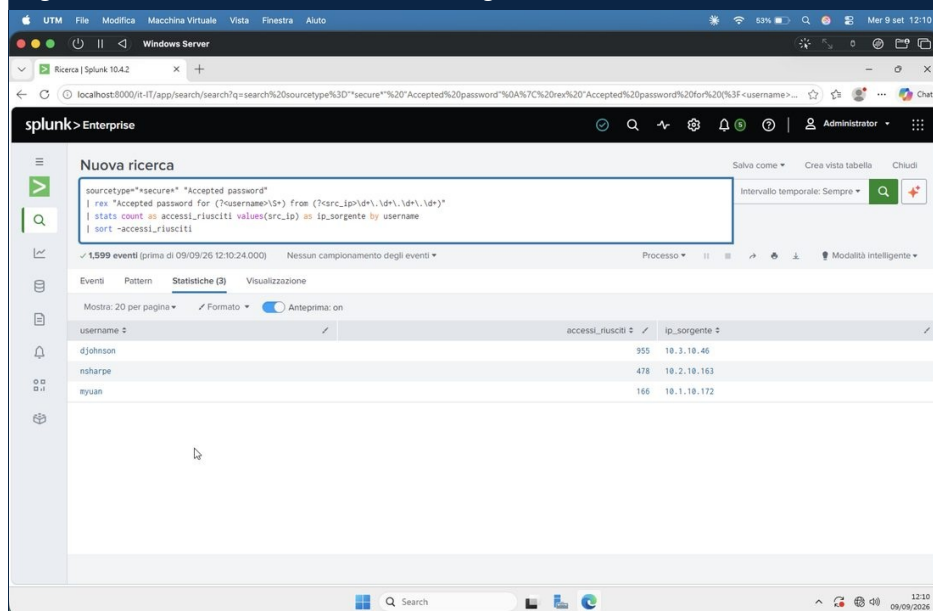
Esito difensivo positivo. La query non restituisce alcun risultato: nessuno dei 182 IP che hanno effettuato brute force è poi riuscito ad autenticarsi. L'attacco, per quanto massiccio, **non ha prodotto compromissioni**.

Verifica degli accessi legittimi

A conferma, si analizzano tutti gli accessi riusciti per utente e IP sorgente.

```
sourcetype="*secure*" "Accepted password"
| rex "Accepted password for (?<username>\S+) from (?<src_ip>\d+\.\d+\.\d+\.\d+)"
| stats count as accessi_riusciti values(src_ip) as ip_sorgente by username
| sort -accessi_riusciti
```

Fig. 8 - Accessi riusciti: solo utenti interni legittimi



Gli accessi riusciti appartengono a soli **tre utenti** (djohnson, nsharpe, myuan), ciascuno da un unico IP della **rete interna** (10.x.x.x). Poiché tutti gli IP attaccanti della Query 4 erano indirizzi pubblici esterni, i due insiemi non si sovrappongono: gli accessi legittimi provengono esclusivamente dall'interno, gli attacchi esclusivamente dall'esterno.

8. Conclusioni

I log analizzati documentano una **campagna brute force distribuita** contro il servizio SSH: 182 sorgenti esterne distinte, oltre 33.000 tentativi di autenticazione falliti, con picchi di centinaia di tentativi al secondo da singoli IP – comportamento tipicamente automatizzato. Nonostante l'intensità, l'attacco è risultato **privo di successo**: nessun IP malevolo ha ottenuto un accesso valido e la totalità degli accessi riusciti proviene da tre utenti interni su indirizzi privati.

Raccomandazioni di incident response

- **Blocco/blacklist** degli IP attaccanti, a partire dai *top offender* (87.194.216.51, 211.166.11.101, ...).
- **Rate-limiting** e adozione di strumenti come fail2ban sul servizio SSH.
- **Autenticazione a chiave pubblica** in sostituzione delle password, per neutralizzare il brute force.
- **Alerting automatico** al superamento di una soglia di tentativi falliti per IP.
- Investigazione separata degli **errori HTTP 500** sulle pagine applicative, come possibile problema di stabilità o scanning.

Nota tecnica: in tutte le query è stato utilizzato il comando rex con espressioni regolari per estrarre dai log i campi non indicizzati (username, IP, porta), come suggerito dalla traccia.